CYBERDEFENDERS | HAWKEYE LAB

# Purple Team Handover Report

Attack observations, defensive investigation, and joint improvement plan

| PREPARED BY | LAB | EVIDENCE |
|---|---|---|
| Abhinav Pratap Singh | CyberDefenders HawkEye | stealer.pcap + Wireshark screenshots |
| **REPORT DATE** | **CAPTURE** | **PRIORITY** |
| 7 November 2026 | 10 April 2019, 20:37-21:40 UTC | High for triage if confirmed on an enterprise endpoint |

## HANDOVER SUMMARY

**A workstation resolved an invoice-themed domain, downloaded an executable over HTTP, and then established recurring authenticated SMTP sessions carrying sensitive data. The capture supports a coordinated red/blue review of the network sequence, exposed credentials, and egress controls. It does not prove how the initial email was delivered or whether the executable ran.**

Handover objective: give defenders a concise, evidence-linked account of what the network trace shows, what the analyst did to investigate it, what remains unknown, and which detections and response steps should be validated in a controlled environment.

Public copy note: credential-bearing screenshots and literal passwords are excluded. The source PCAP and original screenshots remain unchanged.

# 1. Incident Summary and Scope

Scenario: an accountant receives an invoice email containing a download link; suspicious network traffic follows. The supplied PCAP contains 4,003 packets over 01:03:41.561. The affected host in the capture is 10.4.10.132, identified by DHCP as Beijing-5cd1-PC. The organization DNS server observed in the relevant exchange is 10.4.10.4.

The strongest supported sequence is: DNS query for proforma-invoices.com, HTTP retrieval of tkraw_Protected99.exe from 217.182.138.150, public-IP discovery through an HTTP service, then repeated SMTP authentication and message submission to 23.229.162.69:587. The SMTP server greeting identifies Exim 4.91 and the transaction recipient is sales.del@macwinlogistics.in.

## Observed versus inferred

| Evidence-supported observations | Assessment / boundary |
|---|---|
| DNS query/answer, HTTP URI and response, server header, exported-file hash, SMTP sessions, AUTH, recipient, and periodic timing are visible in the capture. | The trace is consistent with a malware-driven collection and exfiltration sequence. It does not independently show the original email, endpoint process execution, persistence, full host scope, or the operator's identity. |
| The decoded message content includes the label HawkEye Keylogger - Reborn v9 and sensitive account material. | This supports an assessment of credential/data theft, but not a full reverse-engineering conclusion about the downloaded executable. |
| No SMTP STARTTLS command is observed before AUTH in the captured sessions. | The captured authentication exchange is visible in the SMTP stream. Sensitive values are not reproduced in this report. |

## Triage priority

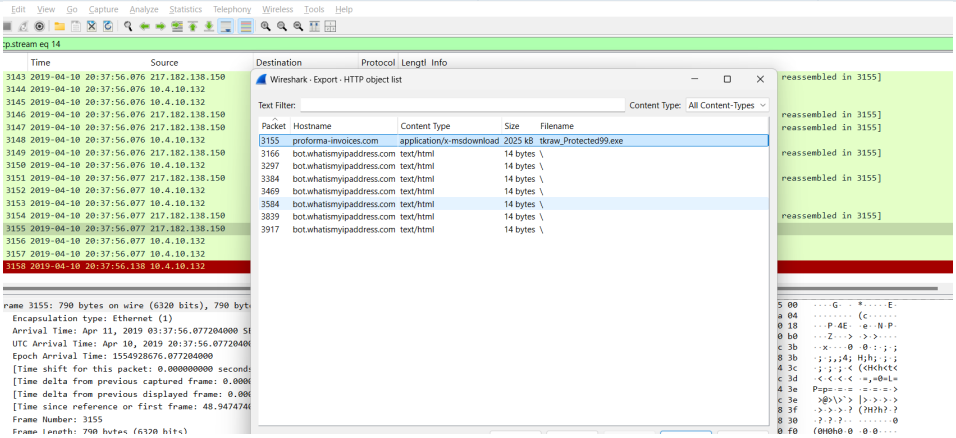
**Recommended priority is high if the same indicators are found on a production endpoint, because an executable was delivered and authentication/data were transmitted through recurring external SMTP sessions. Treat this as provisional until endpoint telemetry confirms execution, exposure, and affected users.**

# 2. Joint Attack and Investigation Timeline

| UTC time / frame | Red-side behavior observed | Blue-side evidence / interpretation |
|---|---|---|
| 20:37:53.791 / 204 | Victim queries proforma-invoices.com. | DNS request from 10.4.10.132 to 10.4.10.4; query captured. |
| 20:37:54.577 / 206 | Domain resolves to 217.182.138.150. | Matching DNS response; transaction ties name to address. |
| 20:37:54.727 / 210 | HTTP GET requests /proforma/tkraw_Protected99.exe. | URI and User-Agent recorded; Windows NT 6.1 is a client string, not verified OS. |
| 20:37:56.077 / 3155 | HTTP server returns executable object. | HTTP 200; 2,025,472 bytes; LiteSpeed. Exported object MD5 verified. |
| 20:38:15.821 / 3166 | Host requests a public-IP lookup. | Response returns 173.66.146.112; address also appears in SMTP greeting. |
| 20:38:16.290-16.562 / 3175, 3188 | Host authenticates to external mail service and addresses a recipient. | Server greeting: Exim 4.91; RCPT TO is visible. Literal credentials withheld. |
| 20:48-21:38 / repeated | Repeated SMTP transactions at near ten-minute intervals. | Seven observed sessions; mean interval is about 10 minutes 4 seconds. |
| Across SMTP message data | Captured message content contains a malware label and account material. | Sensitive data supports the exfiltration assessment; no values reproduced. |

## Attack chain

| DNS | HTTP DELIVERY | PUBLIC-IP CHECK | SMTP EXFIL |
|---|---|---|---|
| proforma-invoices.com<br>217.182.138.150 | tkraw_Protected99.exe<br>LiteSpeed | 173.66.146.112 | 23.229.162.69:587<br>Exim 4.91 |




*Evidence exhibit. Wireshark HTTP object export identifies the executable returned in frame 3155.*

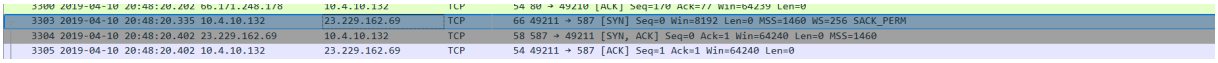
# 3. Red-Team and Blue-Team Perspectives

## Red / adversary-side behaviors visible in the trace

| Observed behavior | Evidence | Defensive meaning |
|---|---|---|
| Invoice-themed domain resolution | DNS frames 204 and 206 | Domain and client can be correlated with subsequent HTTP retrieval. |
| Executable delivery over HTTP | Frame 210 request; frame 3155 response; exported file | An endpoint may have received a suspicious binary. Execution must be checked with endpoint telemetry. |
| External identity/public-IP check | HTTP request and response at frame 3166 | Useful context when correlated with later outbound SMTP; weak signal alone. |
| Authenticated SMTP submission | Frames 3175, 3179, 3188; destination 23.229.162.69:587 | Unexpected SMTP from a user endpoint and visible AUTH are high-value detection opportunities. |
| Recurring transmissions | Sessions at 20:38, 20:48, 20:58, 21:08, 21:18, 21:28, 21:38 UTC | Near-periodic activity is consistent with automated collection or exfiltration. |
| Decoded content label and account material | SMTP DATA stream, reviewed in analyst screenshots | Supports data-theft concern; secret values omitted from this handover. |

## Blue / analyst actions documented in the solve notes

The analyst reviewed capture properties and endpoints, filtered DHCP/DNS/HTTP/SMTP, correlated the DNS query and response, inspected packet 204 and the matching answer, followed the HTTP TCP stream, exported the HTTP object, calculated its MD5, followed SMTP streams, decoded Base64 content, and used external lookups for vendor/geolocation context. The PCAP review confirms key packet facts and the MD5. No malware execution or host remediation is represented as having been performed.




*Evidence exhibit. Packet list shows the client connection to 23.229.162.69 on SMTP submission port 587.*

## Purple-team interpretation

**The most useful joint test is whether defenders can link the domain query, executable retrieval, endpoint file/hash event, and periodic authenticated SMTP egress into a single incident. The lab PCAP provides strong network evidence but lacks host process, email gateway, and identity logs needed to confirm initial access, execution, persistence, and full data scope.**

# 4. Detection and Response Handover

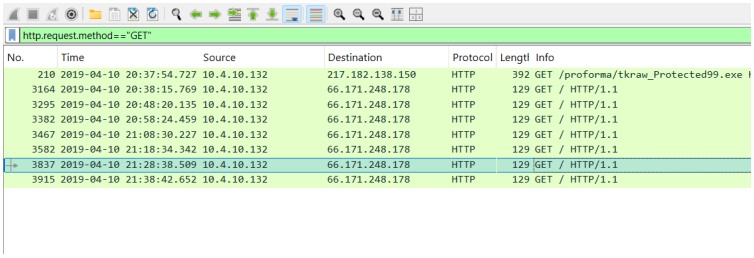
| Detection opportunity | Suggested correlation | Required telemetry / caveat |
|---|---|---|
| Invoice-domain download | DNS query for a newly observed domain followed within minutes by HTTP GET for an executable from the returned address. | DNS + proxy/HTTP logs. Domain IOC is lab-specific; production detections should generalize by behavior. |
| Suspicious executable | Endpoint file creation or download event matching tkraw_Protected99.exe or hash; correlate with outbound network activity. | EDR/file telemetry. Hash is useful for this sample only; do not infer execution from PCAP alone. |
| Unexpected SMTP from workstation | Alert on AUTH to external SMTP submission service from a user endpoint; elevate if no STARTTLS upgrade is observed. | Firewall, network sensor, mail logs. Approved business exceptions should be allowlisted narrowly. |
| Periodic data transfer | Group SMTP transactions by host and destination; alert on repeated egress with intervals near 9-11 minutes and stable recipient or destination. | Flow + SMTP metadata. Cadence is a supporting signal, not a standalone verdict. |
| Credential/data exposure | Detect sensitive account-like content in SMTP DATA with privacy-preserving inspection where authorized; prioritize credential rotation when confirmed. | Mail/security telemetry and incident process. Do not store recovered secrets in alert tickets or public reports. |

## Recommended response sequence

1. Preserve the original PCAP, exported-object hashes, and relevant logs; record provenance and time zone. 2. If endpoint evidence supports compromise, isolate the workstation while preserving volatile evidence. 3. Search DNS, proxy, EDR, and mail/firewall logs for the domain, file hash, destination IP, recipient, and related time window. 4. Block or restrict the domain and SMTP destination according to local change control; prevent direct workstation SMTP egress except approved services. 5. Rotate credentials and revoke sessions for any secrets confirmed exposed; do not repeat them in tickets or reports. 6. Determine whether the file executed, identify persistence or additional payloads with endpoint forensics, and scope affected accounts/data. 7. Recover from a known-good state and validate egress controls before returning the host to service.

## Control improvements for joint validation

Require TLS for SMTP submission and fail closed if encryption is unavailable; centralize outbound mail through managed relays; alert on new external recipients and anomalous sender behavior; apply web controls for executable downloads; and retain endpoint process/file telemetry alongside network flow and DNS logs.




*Evidence exhibit. Repeated HTTP public-IP lookup requests occur on a similar cadence to the SMTP sessions.*

# 5. Purple-Team Handover Record

## Indicators to retain for this lab case

| Type | Value | Use / confidence |
|---|---|---|
| Internal host | 10.4.10.132 \| Beijing-5cd1-PC | Capture-supported; DHCP and network endpoint evidence. |
| DNS server | 10.4.10.4 | Capture-supported for the observed DNS transaction. |
| Domain / resolved IP | proforma-invoices.com \| 217.182.138.150 | Capture-supported; QNAME packet 204, answer packet 206. |
| HTTP object | tkraw_Protected99.exe \| MD5 71826BA081E303866CE2A2534491A2F7 | Object exported from supplied PCAP; hash recomputed. SHA-256 62099532750DAD1054B127689680C3859003 3FA0BDFA4FB40C7B4DCB2607FB11. |
| SMTP destination | 23.229.162.69:587 \| Exim 4.91 | Capture-supported server greeting and conversation. |
| SMTP recipient | sales.del@macwinlogistics.in | Capture-supported RCPT TO; treat as a lab indicator, not attribution. |
| SMTP cadence | About 10 minutes 4 seconds | Seven observed sessions; calculated from greeting timestamps. |
| Public IP seen in trace | 173.66.146.112 | Returned by public-IP lookup service and repeated in SMTP greeting; geolocation is not attribution. |

## ATT&CK; context

T1105 (Ingress Tool Transfer) is a reasonable behavior mapping for the inbound HTTP executable transfer. T1048.003 (Exfiltration Over Unencrypted Non-C2 Protocol) is a reasonable mapping for the visible, periodic SMTP data submission without a captured STARTTLS upgrade. These are behavior mappings, not claims about a complete adversary playbook. The PCAP does not establish the phishing email itself or the execution process.

## Unresolved questions for a real incident

Was the invoice email delivered and opened? Did the executable execute, and under which user? What process created the SMTP connections? Which additional files, accounts, and hosts were affected? What data was transmitted beyond the contents visible in the capture? Was the destination or recipient authorized? These require email gateway, EDR, authentication, firewall, and data-owner evidence.

## Handover conclusion

**The blue-team investigation converted a packet trace into a defensible network narrative and a useful set of indicators. The red/blue handover should prioritize endpoint confirmation, credential rotation, SMTP egress controls, and cross-source correlation. All observed actions, inferred behavior, and proposed controls are separated in this report; no unverified execution or remediation is claimed.**

Primary evidence: stealer.pcap, SHA-256 22106927c11836d29078dfbec20be9d6b61b1f3f47f95c758acc47a1fb424e51. Supporting screenshots: selected Wireshark exhibits from the analyst's README. Sensitive screenshots with plaintext credentials were excluded.

End of report